



Unidad Didáctica 6: SEGURIDAD EN LAS COMUNICACIONES

Redes

ÍNDICE

Contenido

1.	INTRODUCCIÓN	3
2.	OBJETIVOS	5
3.	TEMA 6: SEGURIDAD EN LAS COMUNICACIONES	6
3.1.	INTRODUCCIÓN AL CIBERESPACIO	6
3.2.1.	<i>Agentes del ciberespacio</i>	6
3.2.2.	<i>Objetivos del ciberespacio</i>	8
3.2.3.	<i>Ciberdefensa y Ciberseguridad en España</i>	12
3.2.	SEGURIDAD EN LOS EQUIPOS.....	14
3.2.1.	<i>Los tres pilares de la seguridad</i>	14
3.2.2.	<i>Qué se protege</i>	15
3.2.3.	<i>De qué se protege</i>	16
3.2.4.	<i>Mecanismos para una protección integral</i>	16
3.3.	SEGURIDAD FÍSICA.....	17
3.3.1.	<i>Amenazas al hardware y medidas de protección</i>	17
3.3.2.	<i>Importancia de proteger los equipos del propio personal</i>	18
3.3.3.	<i>Relación entre hardware y software</i>	19
3.4.	AMENAZAS DE UNA RED	19
3.4.1.	<i>Clasificación según la naturaleza del ataque</i>	22
3.5.	SERVICIOS DE SEGURIDAD	24
3.5.1.	<i>Confidencialidad</i>	24
3.5.2.	<i>Autenticación</i>	24
3.5.3.	<i>Integridad</i>	24
3.5.4.	<i>No repudio</i>	25
3.5.5.	<i>Control de acceso</i>	25
3.6.	CRIPTOGRAFÍA	26
3.6.1.	<i>Cifrado de enlace vs. Cifrado extremo a extremo</i>	26
3.6.2.	<i>Cifrado simétrico</i>	27
3.6.3.	<i>Implementaciones típicas de Cifrado Simétrico</i>	28
3.6.4.	<i>Cifrado asimétrico</i>	29
3.6.5.	<i>Implementaciones mas comunes de Cifrado asimétrico</i>	31
3.6.6.	<i>Uso combinado: negociación de claves</i>	32
3.6.7.	<i>Funciones Hash</i>	33
3.6.8.	<i>Firma digital</i>	34
4.	CONCLUSIONES	38
5.	BIBLIOGRAFÍA	40

1. Introducción

¡Bienvenido a la asignatura de Redes!

La comunicación es un proceso fundamental en cualquier ámbito de la sociedad, y en la era digital adquiere una relevancia aún mayor. En la actualidad, la mayoría de las interacciones — desde el envío de correos electrónicos hasta la realización de transacciones financieras— se llevan a cabo a través de redes de comunicación interconectadas a nivel mundial. Esta infraestructura tecnológica, cada vez más compleja y extensa, requiere de una protección robusta ante posibles amenazas que puedan comprometer la confidencialidad, la integridad y la disponibilidad de la información.

En esta Unidad 6, enfocada en la **Seguridad en las Comunicaciones**, se abordan los conceptos, herramientas y prácticas esenciales para asegurar la transmisión de datos en diferentes entornos y protocolos de comunicación. Para ello, se estudiarán tanto los fundamentos de la criptografía como la aplicación práctica de medidas de seguridad en redes, servicios web, sistemas de mensajería y otras plataformas digitales de uso frecuente. Además, se revisarán los principales estándares y protocolos de seguridad, analizando casos reales que ilustran la importancia de una protección adecuada en las organizaciones y en la vida cotidiana de las personas.

Uno de los pilares fundamentales de la seguridad en las comunicaciones es la **criptografía**, cuyas técnicas permiten convertir datos legibles (texto plano) en datos cifrados (texto cifrado) que solo el receptor autorizado puede descifrar. Dentro de la criptografía, existen dos enfoques principales: la **criptografía de clave privada (simétrica)** y la **criptografía de clave pública (asimétrica)**.

A lo largo de esta unidad, profundizaremos en cómo estos métodos criptográficos se combinan para reforzar la seguridad en las diferentes **capas de la comunicación**, desde la capa de aplicación (por ejemplo, en los protocolos de correo electrónico y mensajería) hasta la capa de transporte (TLS/SSL) o la capa de red (IPsec). Abordaremos, además, el uso de **firmas digitales** para garantizar la autenticidad y el no repudio de los mensajes, y exploraremos cómo los protocolos de intercambio de claves (como Diffie-Hellman) aseguran la negociación de claves de manera segura incluso en un entorno vulnerable a escuchas.

En definitiva, comprender los fundamentos de la criptografía y los protocolos asociados es esencial para cualquier profesional o estudiante interesado en la **Seguridad en las Comunicaciones**. Estos conocimientos no solo permiten proteger los datos de manera efectiva, sino que también sientan las bases para diseñar e implementar entornos confiables, adaptables a los continuos avances tecnológicos y a las amenazas emergentes de la ciberseguridad.

Motivación

La creciente adopción de tecnologías de la información y las comunicaciones trae consigo múltiples beneficios, pero también expone a organizaciones y usuarios a diferentes tipos de ataques. Vulnerabilidades en los protocolos de red, la falta de cifrado o la mala configuración de servicios pueden resultar en robo de datos, suplantación de identidad o sabotaje. Entender cómo funcionan las amenazas y qué herramientas y buenas prácticas se pueden aplicar para

contrarrestarlas es un elemento indispensable para quienes aspiran a desempeñarse en roles técnicos, de gestión o auditoría. Al final, proteger las comunicaciones no solo evita pérdidas económicas, sino que también fortalece la confianza de clientes, colaboradores y ciudadanos en la infraestructura digital.

Cada vez son más frecuentes los ataques que buscan interceptar comunicaciones, robar datos o sabotear servicios críticos. La seguridad en las comunicaciones no solo implica defenderse de ciberdelincuentes que podrían lucrar con datos sensibles, sino también resguardar la continuidad de las operaciones diarias de las organizaciones y la confianza de los usuarios.

Hoy en día, casi todas las actividades personales y profesionales se apoyan en servicios y plataformas digitales: desde el envío de correos electrónicos y mensajería instantánea hasta transacciones bancarias, compras en línea o videoconferencias. Esta mayor dependencia implica que una interrupción o vulnerabilidad en las comunicaciones puede tener consecuencias masivas y afectar la vida diaria de millones de personas.

Los ciberdelincuentes y actores maliciosos han refinado sus tácticas, adoptando métodos avanzados (p.ej., ataques de día cero, ransomware, phishing dirigido) que pueden burlar medidas de seguridad tradicionales.



Ten en cuenta

Resulta crucial que los profesionales y estudiantes adquieran habilidades técnicas y conocimientos integrales para diseñar, implementar y evaluar sistemas de comunicación que garanticen niveles apropiados de seguridad, adaptándose a un entorno de amenazas en constante evolución.

2. Objetivos

El estudiante o profesional estará en capacidad de identificar riesgos, aplicar métodos de cifrado adecuados, configurar protocolos y herramientas de seguridad, así como diseñar y gestionar políticas que fortalezcan la Seguridad en las Comunicaciones en cualquier tipo de organización o contexto. Al finalizar la unidad, los estudiantes deberán ser capaces de:

- Analizar y comprender las vulnerabilidades en la transmisión de datos
- Conocer y aplicar técnicas de criptografía de clave simétrica y asimétrica
- Implementar protocolos y herramientas de seguridad en las capas de red y transporte
- Integrar el uso de certificados digitales y firmas electrónicas
- Diseñar y evaluar políticas de seguridad y planes de contingencia
- Mantenerse actualizado en nuevas tendencias y amenazas emergentes

3. Tema 6: Seguridad en las Comunicaciones

3.1. Introducción al Ciberespacio

El ciberespacio se define como un entorno global y dinámico en el que convergen todas las infraestructuras de tecnología de la información —en particular Internet—, así como redes y sistemas de información y de telecomunicaciones. Esta concepción, expuesta en la *Estrategia de Ciberseguridad Nacional (2013)*, subraya la extraordinaria complejidad y el alcance de un espacio virtual que carece de fronteras físicas claramente definidas.

En este ámbito se despliegan desde simples interacciones cotidianas —como el intercambio de mensajes y la consulta de sitios web— hasta procesos de misión crítica para gobiernos, fuerzas armadas, industrias y organizaciones de todos los sectores. Gracias a la interconexión masiva, el ciberespacio ha impulsado el crecimiento económico, la innovación tecnológica y la comunicación instantánea; sin embargo, también ha abierto la puerta a nuevas amenazas y desafíos, tales como ataques cibernéticos, espionaje digital, robo de información, propagación de desinformación o incluso la interrupción de servicios esenciales.

La Organización del Tratado del Atlántico Norte (OTAN) reconoció la importancia del ciberespacio en 2016 al declararlo su **quinto dominio de operaciones**, equiparándolo con los dominios tradicionales de la guerra (tierra, mar, aire y espacio ultraterrestre). Esta decisión pone de relieve el carácter estratégico que tienen hoy en día las acciones cibernéticas, pues un ataque exitoso en el plano digital puede desencadenar consecuencias igual o más graves que un ataque físico convencional.



Ilustración 1: 4 dominios clásicos. Tierra, Mar, Aire y Espacio. Fuente: Propia

3.2.1. Agentes del ciberespacio

Al examinar el entorno digital, es fundamental comprender los diferentes perfiles de actores que intervienen y sus motivaciones. Aunque los términos empleados pueden variar según las fuentes y contextos, se presentan algunas categorías generales que sirven para describir a los principales agentes en el ciberespacio

Hacker	De acuerdo con la definición más difundida por la RAE, se les considera “piratas informáticos” que cometen delitos informáticos. Sin embargo, el término “hacker” también se ha diversificado en subcategorías basadas en su conducta y objetivos: 1. White hat: Hackers “éticos” o “de sombrero blanco” que utilizan sus conocimientos para realizar pruebas de penetración, identificar vulnerabilidades y reforzar la seguridad de los sistemas. 2. Grey hat: Se sitúan en una zona intermedia. A veces realizan actividades de hacking sin autorización explícita, pero sus motivaciones no siempre persiguen un provecho económico o un perjuicio deliberado. 3. Black hat: Hackers “maliciosos” o “de sombrero negro” cuyo fin es obtener beneficios ilícitos, causar daños o robar información.
Script kiddie	Un subgrupo dentro de la categoría de hackers que no desarrollan sus propias herramientas, sino que emplean aplicaciones o scripts diseñados por otros. A menudo carecen de conocimientos avanzados, pero son los más numerosos debido a la facilidad de acceso a recursos en línea.
Cibercriminal	1. IPv6 Individuo o grupo que comete delitos utilizando medios informáticos, con el propósito de obtener un beneficio económico, robar información o causar daños a personas u organizaciones. 2. Las actividades de ciberdelincuencia abarcan desde fraudes en línea y robo de identidades, hasta la distribución de ransomware o software malicioso. 3. Aunque a menudo se emplee el término “hacker” para referirse a ellos, el cibercriminal propiamente dicho se enfoca fundamentalmente en objetivos criminales y en ganancias ilegales.

Ciberactivista

Este Utiliza las tecnologías de la información y la comunicación (TIC), pero no con fines delictivos, sino para difundir ideas, movilizar a la sociedad o protestar ante situaciones específicas. Pueden organizar campañas en redes sociales, promover peticiones en línea, filtrar información que consideren de interés público o llevar a cabo actos de “hacktivismo” simbólico (p. ej., defacement de sitios web) para llamar la atención sobre causas políticas o sociales.

A diferencia del cibercriminal, el ciberactivista suele justificar sus acciones en un marco ideológico, aunque en algunos casos cruza la línea legal dependiendo de las tácticas que use.

3.2.2. Objetivos del ciberespacio

En el ciberespacio, los atacantes (ya sean hackers, cibercriminales u otros actores) pueden perseguir una variedad de **objetivos** relacionados con la información y los sistemas que sustentan nuestras sociedades. Estos objetivos se suelen clasificar en diferentes ámbitos según su naturaleza: **militar, civil, político y social, y económico o industrial**.

Carácter Militar

Sistemas TIC y C2: En el entorno militar, las Tecnologías de la Información y la Comunicación (TIC) y los sistemas de Comando y Control (C2) son esenciales para la coordinación de operaciones, la logística y la toma de decisiones estratégicas.

- Incluye **infraestructuras de redes, sistemas de localización y navegación (GPS), enlaces de radio** para comunicación en campo y la **cadena logística** que suministra recursos a las fuerzas armadas.
- La interrupción o manipulación de estos sistemas puede debilitar la capacidad de respuesta y defensa de un país, además de comprometer misiones críticas.

Carácter Civil

Infraestructuras críticas: Son aquellos servicios fundamentales para el buen funcionamiento de una nación, por ejemplo **Redes eléctricas, sistemas de distribución de agua, transporte (ferrocarriles, aeropuertos)**, entre otros.

- Un ataque exitoso a estas infraestructuras puede provocar graves consecuencias, como cortes de suministro, caos en el transporte o falta de acceso a recursos esenciales.

Servicios críticos (emergencias, alerta ciudadana...): Abarca los mecanismos de **salud y emergencias** (hospitales, ambulancias, número de emergencias), así como los **sistemas de alerta** ante desastres naturales o eventos de gran escala.

- Su inutilización o manipulación puede poner en riesgo la vida de la población y dificultar la reacción ante crisis.

Servicios ciudadanos: Incluye aspectos como **control de tráfico aéreo, ferrocarriles, o sistemas de suministro de agua** y energía en zonas urbanas.

- Dada su influencia directa en la vida cotidiana, un ataque a estos servicios puede ocasionar perturbaciones sociales y económicas.

Carácter político y social

Gobiernos y partidos políticos: La información sensible que manejan (planes, bases de datos ciudadanas, estrategias electorales) resulta sumamente valiosa.

- Ataques a webs oficiales o filtraciones de datos pueden desestabilizar la confianza pública y alterar procesos democráticos.

Webs y Medios de Comunicación Social (MCS): Controlar o alterar la difusión de información a través de medios tradicionales (periódicos, televisión) o redes sociales (X, Facebook, etc.) puede influir en la **opinión pública** y en la percepción de la realidad.

- Los ciberataques dirigidos a estos medios pueden servir para propagar desinformación, censurar noticias o manipular contenidos.

Acceso a Internet, telefonía móvil y satelital: Son canales de comunicación claves para el ejercicio de derechos ciudadanos y la cohesión social.

- Un ataque masivo que bloquee el acceso a Internet o servicios telefónicos puede incomunicar a la población y dificultar la coordinación en situaciones de emergencia.

Carácter económico o industrial

Contratistas de Defensa: Empresas que desarrollan tecnología y equipamiento militar y que suelen colaborar estrechamente con el sector gubernamental.

- El robo de propiedad intelectual o la infiltración en sus redes puede proporcionar ventajas a adversarios estatales o a la competencia ilegal.

Propiedad intelectual, información personal: Incluye **secretos industriales, investigación y desarrollo** (I+D), patentes e información sensible de empleados y clientes.

- Su extracción o venta en el mercado negro puede ser muy lucrativa, además de provocar daños competitivos y de reputación.

Dispositivos embebidos: Desde sistemas en maquinaria de producción hasta el Internet de las Cosas (IoT) que se usa en entornos industriales.

- La manipulación de estos dispositivos puede causar fallos en la cadena de producción, sabotaje y potenciales riesgos para la seguridad física de los empleados.

Centros de generación y distribución de energía: Centrales de generación (nuclear, hidroeléctrica, eólica, etc.) y redes de distribución de electricidad, gas o petróleo.

- Un ataque a estos sistemas puede producir apagones masivos, restricciones energéticas y graves pérdidas económicas.

Banca y finanzas: Entidades bancarias, fintech, bolsas de valores y otros servicios financieros en línea.

- El acceso no autorizado a datos financieros o la manipulación de sistemas transaccionales puede derivar en cuantiosas pérdidas económicas, robos de identidad y daños a la estabilidad del sistema monetario.

3.2.3. Ciberdefensa y Ciberseguridad en España

A grandes rasgos, la **ciberdefensa** y la **ciberseguridad** en España se articulan a través de diversos organismos dependientes principalmente del **Ministerio del Interior** y de otros ministerios clave, cada uno con competencias específicas.

1. Seguridad de Infraestructuras Críticas (CNPIC)

- **CNPIC (Centro Nacional de Protección de Infraestructuras Críticas)**
 - Dependiente del **Ministerio del Interior**, se encarga de la **protección de las infraestructuras críticas** a escala nacional.
 - Colabora con otros organismos, tanto públicos como privados, para **prevenir y responder** ante incidentes que puedan afectar a los servicios esenciales (transporte, energía, agua, salud, etc.).
 - Elabora planes y directrices para que las empresas y administraciones que gestionan infraestructuras críticas mejoren su **nivel de seguridad y resiliencia ante ciberataques**.

2. Seguridad de Sistemas de Información (SI) de utilización conjunta de las FCSE (CETSE)

- **CETSE (Centro de Estudios y Tratamiento de la Seguridad del Estado)**
 - También dependiente del **Ministerio del Interior**, coordina la **seguridad de los sistemas de información** compartidos por las **Fuerzas y Cuerpos de Seguridad del Estado (FCSE)**.
 - Su misión principal es garantizar que los **datos y comunicaciones** entre la Policía Nacional, la Guardia Civil y otros cuerpos competentes se gestionen y protejan adecuadamente frente a **ciberamenazas**.
 - Facilita la **interoperabilidad** de sistemas y el **intercambio seguro de información** para optimizar el trabajo conjunto de estos cuerpos.

3. Seguridad de Sistemas de Información (SI) de la Industria (CERTSI)

- **CERTSI (Equipo de Respuesta a Incidentes de Seguridad de la Industria)**
 - Es el **Centro de Respuesta a Incidentes** enfocado en la industria, resultado de la colaboración entre el **CNPIC** (Ministerio del Interior) y el **INCIBE** (Instituto Nacional de Ciberseguridad), bajo el **Ministerio de Industria, Energía y Turismo** (actualmente integrado en el Ministerio de Asuntos Económicos y Transformación Digital).
 - Ofrece asistencia y coordinación ante **incidentes cibernéticos** que afecten a organizaciones públicas y privadas del sector industrial.

- Proporciona **alertas, avisos y guías** de buenas prácticas de seguridad, impulsando la **concienciación y la resiliencia** empresarial frente a riesgos digitales.

4. Ciberdelitos (BIT y GDT)

- **BIT (Brigada de Investigación Tecnológica) de la Policía Nacional**
 - Unidad especializada en la **investigación de delitos tecnológicos**, como fraudes, suplantaciones de identidad, estafas online o distribución de material ilícito en la red.
 - Colabora con otras fuerzas de seguridad y organismos internacionales para perseguir a los ciberdelincuentes y **luchar contra la criminalidad en Internet**.
- **GDT (Grupo de Delitos Telemáticos) de la Guardia Civil**
 - Otra unidad específica para combatir el **ciberdelito**, dependiente igualmente del **Ministerio del Interior**.
 - Se ocupa de investigar desde **ataques informáticos** dirigidos a infraestructuras hasta **estafas online**, así como la **protección de menores** en la red y la persecución de redes delictivas que operan a través de medios telemáticos.

Ambas unidades (BIT y GDT) son clave para la **prevención, investigación y persecución** de delitos cometidos a través de sistemas informáticos y redes de comunicación.



Ilustración 2: Equipos en España contra delitos cibernéticos. Fuente: Propia

3.2. Seguridad en los equipos

La **seguridad en los equipos informáticos** es un proceso continuo y multidimensional que busca proteger tanto los componentes físicos (hardware) como los lógicos (software y datos) frente a una gran variedad de amenazas. Aunque hoy en día hablemos de **ciberseguridad** y dispongamos de multitud de herramientas y protocolos para proteger la información, no siempre fue así. Hasta finales de los años 80, por ejemplo, la seguridad en la red era prácticamente inexistente: se confiaba en que nadie atacaría un sistema que, en apariencia, no tenía “valor” para extraños. Sin embargo, en 1988, el llamado **gusano de Robert T. Morris** se propagó por ARPANET y logró dejar inutilizable alrededor del 10% de la red, marcando un hito que evidenció la vulnerabilidad de los equipos y la necesidad de desarrollar métodos para defenderlos.

A partir de entonces, apareció el **CERT (Computer Emergency Response Team)**, entre otras organizaciones, con la misión de proporcionar una respuesta rápida ante incidentes de seguridad e informar de potenciales vulnerabilidades a usuarios y administradores de sistemas. Este enfoque proactivo permitió que, progresivamente, la protección de la información fuera ganando relevancia dentro de las instituciones, extendiéndose también a las empresas privadas y los usuarios finales.

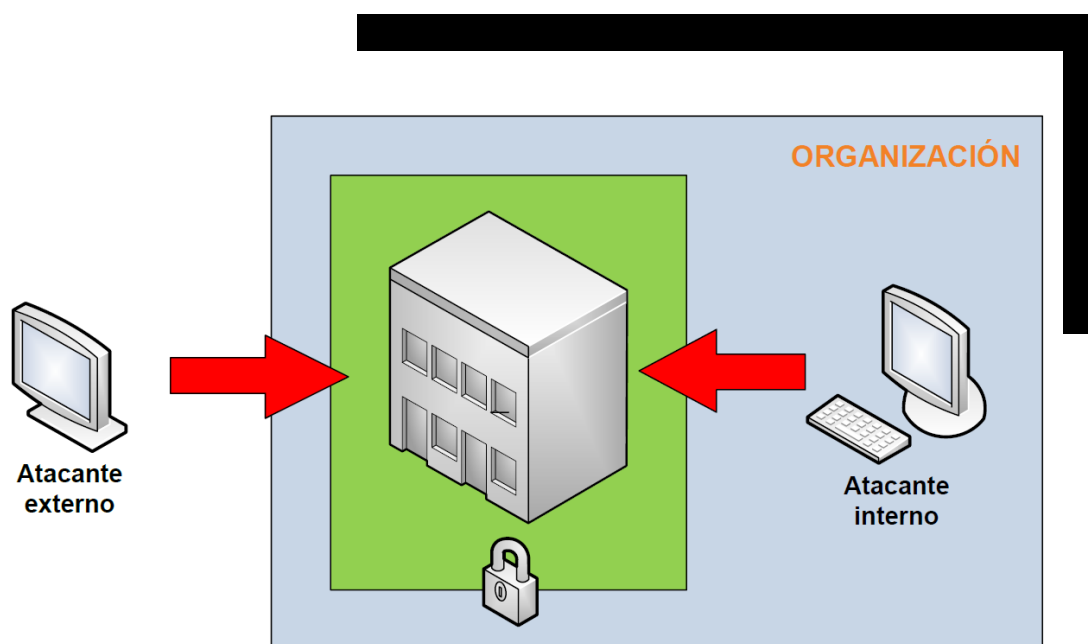


Ilustración 3. Representación gráfica de la seguridad. Fuente: UAX Redes

3.2.1. Los tres pilares de la seguridad

Para entender la seguridad en los equipos, resulta esencial conocer los **tres pilares** que la sostienen:

1. **Confiabilidad (o confidencialidad)**

Es la capacidad de proteger la información para que únicamente pueda ser vista o

utilizada por las personas que estén autorizadas. Un ejemplo práctico es la implementación de **contraseñas seguras** y sistemas de **cifrado** de disco o de correo electrónico. Con ello se evita que un atacante, o incluso un empleado curioso sin permisos adecuados, acceda a datos sensibles.

2. **Integridad**

Asegura que la información no se altere o manipule sin autorización. Para ello, se pueden emplear **controles de acceso** estrictos, llevar **registros de auditoría (logs)** y usar **firmas digitales**. En un entorno de bases de datos, la integridad resulta básica para impedir la inyección de datos falsos o la eliminación fraudulenta de información valiosa (como facturas, registros médicos, etc.).

3. **Disponibilidad**

Garantiza que los sistemas y la información estén disponibles cuando los usuarios los necesiten. Los ataques de denegación de servicio (DoS/DDoS), por ejemplo, buscan saturar un servidor y privar a los clientes de su uso. Para contrarrestar esto, se recurre a **sistemas redundantes, balanceadores de carga o planes de continuidad de negocio** que permitan a la organización seguir operando si una parte de su infraestructura cae.

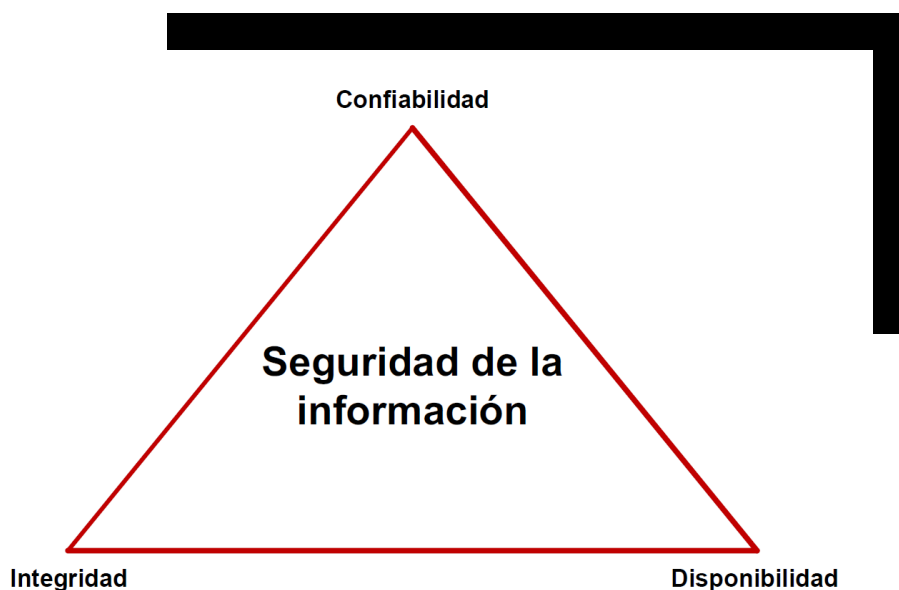


Ilustración 4. Seguridad de la información. Fuente: UAX Redes

3.2.2. **Qué se protege**

- **Hardware:** Incluye equipos, componentes de red (routers, switches) y dispositivos de almacenamiento. Protegerlos implica, por ejemplo, restringir el acceso físico a la sala de servidores para evitar que alguien desconecte un disco duro o instale hardware malicioso.
- **Software:** Comprende sistemas operativos, aplicaciones y librerías que interactúan con el hardware. Aquí entran en juego las **actualizaciones de seguridad**, la instalación de

antivirus, la configuración de **firewalls** y la **segmentación de redes** para minimizar el riesgo de que un fallo en una aplicación afecte al resto de la infraestructura.

- **Datos:** Se refiere a toda la información manejada por el sistema. Este es, a menudo, el activo más valioso de una organización. Protegerlo pasa por realizar **copias de seguridad (backups)** periódicas, emplear **cifrado** tanto en reposo (discos duros, bases de datos) como en tránsito (comunicación a través de redes públicas), y definir **permisos de acceso** muy claros a cada tipo de dato.

3.2.3. De qué se protege

1. Personas

Sorprendentemente, buena parte de los incidentes de seguridad se deben a **errores humanos** o a personal interno que abusa de sus privilegios. Por ejemplo, un empleado que abre un correo de phishing y descarga sin querer un malware o un técnico que comparte contraseñas en un archivo de texto sin medidas de cifrado.

2. Amenazas lógicas

Engloban los **virus, gusanos, troyanos, puertas traseras, rootkits** y otras piezas de software malicioso que aprovechan vulnerabilidades de sistemas y aplicaciones. El gusano de Morris o los ataques masivos de ransomware ilustran cómo estos programas pueden propagarse con rapidez y causar graves perjuicios económicos y operativos.

3. Catástrofes

Aunque resulten menos frecuentes, **inundaciones, incendios, terremotos** o fallos eléctricos pueden dañar física o lógicamente un centro de datos. Planificar copias de seguridad externas y sitios alternativos es fundamental para mantener la continuidad de la actividad.

3.2.4. Mecanismos para una protección integral

- **Prevención:** Herramientas y prácticas para impedir la entrada de amenazas durante la operación normal (por ejemplo, **antivirus, firewalls, sistemas de filtrado de correo**, políticas de contraseñas seguras, etc.).
- **Detección:** Soluciones orientadas a descubrir actividades anómalas o no autorizadas (como **Sistemas de Detección de Intrusos**, monitoreo de logs o auditorías regulares).
- **Recuperación:** Acciones y planes diseñados para **restaurar** el funcionamiento si se produce un incidente (backups actualizados, **planes de contingencia** y, en casos extremos, la **reconstrucción** de sistemas dañados). Las herramientas de **análisis forense** ayudan a investigar cómo ocurrió el ataque y a determinar su alcance.



Ten en cuenta

En conjunto, todas estas medidas permiten a las organizaciones minimizar los riesgos, responder con rapidez ante incidentes y, sobre todo, **garantizar la continuidad** de los servicios críticos. Hoy, más que nunca, la protección de hardware, software y datos es una tarea estratégica que requiere una mezcla de tecnología, formación continua y buenas prácticas de gestión para hacer frente a un entorno de amenazas en constante evolución.

3.3. Seguridad Física

La **seguridad física** constituye el primer escalón para proteger cualquier sistema informático, puesto que de nada sirven los cortafuegos o los sistemas de cifrado si un intruso puede acceder directamente al hardware y manipularlo o sustraerlo. En las organizaciones, el equipamiento (servidores, ordenadores de alto rendimiento, dispositivos de almacenamiento, etc.) representa una **inversión económica muy elevada**, por lo que resulta imprescindible aplicar medidas de **control y prevención** que reduzcan las posibilidades de un ataque físico. Además, estas medidas deben planificarse considerando el **entorno** (ubicación geográfica, condiciones ambientales, amenazas más probables) y el **presupuesto** disponible.

3.3.1. Amenazas al hardware y medidas de protección

Acceso físico no autorizado

Un atacante que logre entrar en la sala de servidores o acceder a un ordenador corporativo puede vulnerar la seguridad incluso sin grandes conocimientos técnicos. Por ejemplo, podría **robar o reemplazar** discos duros, desconectar redes, instalar dispositivos espía o, en el peor de los casos, sustraer todo el equipo.

Prevención:

- **Creación de áreas de acceso restringido:** Por ejemplo, utilizar cerraduras biométricas, tarjetas de proximidad o sistemas de control de acceso para limitar quién puede ingresar al lugar donde se aloja el hardware.
- **Sistemas de videovigilancia:** Cámaras y sensores de movimiento que registren la actividad en todo momento.

Detección:

- **Alarmas y sensores** que avisen si alguien intenta forzar una puerta o abrir un rack de servidores sin autorización.
- **Personal de seguridad** o guardias que realicen rondas periódicas y verifiquen credenciales de los visitantes.

Desastres del entorno

Factores como **inundaciones, incendios y terremotos** pueden causar daños irreversibles al hardware. Por ejemplo, una sala de servidores que se inunde por una tubería rota puede resultar en la pérdida total de equipos y datos.

Prevención:

- **Sistemas de extinción de incendios** apropiados para equipamiento electrónico (por ejemplo, gas inerte en lugar de agua).
- **Diseño de infraestructuras con redundancia:** Alimentación ininterrumpida (SAI), climatización especializada y racks herméticos o elevados.
- **Ubicar los equipos** en zonas del edificio menos susceptibles a daños ambientales (pisos altos para evitar inundaciones, cuartos con buen aislamiento).

Protección de datos frente a la extracción física

Incluso si el hardware permanece en su lugar, un atacante puede intentar **interceptar** la información que viaja por la red (eavesdropping) o **copiar** datos almacenados localmente. También podría aprovechar la **emisión de señales electromagnéticas** para obtener datos de pantallas o cables (ataques más sofisticados conocidos como TEMPEST).

Prevención:

- **Cifrado de discos** y discos externos, de modo que si alguien roba el dispositivo, no pueda acceder a su contenido.
- **Bloqueo y etiquetado** de puertos USB o DVD en servidores y estaciones de trabajo críticas.
- **Separación física** de redes sensibles (redes de administración, por ejemplo) para evitar escuchas no autorizadas.

3.3.2. Importancia de proteger los equipos del propio personal

Puede parecer contradictorio, pero el **factor humano** dentro de la organización a menudo representa la mayor fuente de riesgo. Un empleado con **acceso legítimo** podría, voluntariamente o por descuido, cometer acciones que comprometan la seguridad física y lógica de los equipos:

- **Ingeniería social:** El atacante persuade o engaña a un empleado para que revele credenciales, deje una puerta abierta o comparta información confidencial.
- **Shoulder surfing:** Alguien observa por encima del hombro para obtener contraseñas o información confidencial mientras un trabajador inicia sesión.
- **Basureo** (dumpster diving): Revisar la basura o papeles descartados para hallar información útil (contraseñas impresas, datos de configuraciones, etc.).

Para mitigar estos riesgos, se aplican principios como la **necesidad de saber** (cada persona solo accede a la información estrictamente necesaria para su trabajo), el **conocimiento parcial o distribuido** (ningún empleado tiene acceso total a todos los sistemas) y la **rotación de funciones** (nadie permanece indefinidamente en el mismo puesto crítico, lo que dificulta la acumulación de excesivos privilegios).

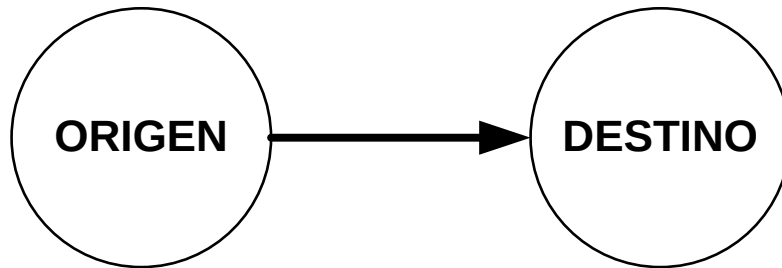
3.3.3. Relación entre hardware y software

Aunque la protección física del hardware sea esencial, este por sí solo es **inútil** sin el **software** que le da vida. Por lo tanto, los planes de seguridad deben incluir también la supervisión y actualización de aplicaciones y sistemas operativos:

- **Necesidad de programas:** Sin software, el hardware no puede ejecutar procesos ni almacenar ni procesar datos útiles.
- **Fallos de programación:** Cualquier aplicación, por muy robusta que parezca, puede contener vulnerabilidades que un atacante podría explotar (desbordamientos de memoria, inyecciones de código, puertas traseras involuntarias, etc.).
- **Malware:** Virus, troyanos, gusanos y otros tipos de software malicioso buscan causar el mayor daño posible o robar información. La instalación de **antivirus**, **sistemas de detección de intrusos (IDS)** y el **parqueo regular** de las aplicaciones son medidas cruciales para reducir el riesgo.
- **Menor nivel de privilegios:** Una buena práctica es que las aplicaciones y usuarios funcionen con los permisos mínimos necesarios, evitando que un fallo o intrusión se extienda a todo el sistema.

3.4. Amenazas de una Red

La **comunicación “normal”** en una red telemática se refiere a ese intercambio de información en el cual emisor y receptor se transmiten datos sin interrupciones ni alteraciones imprevistas. Dicho de otro modo, el flujo de los paquetes de información (mensajes, peticiones, respuestas, etc.) ocurre según lo esperado y sin que nadie más (además de las partes autorizadas) observe o manipule ese tráfico.



Cualquier acción que **interrumpa o altere** este flujo normal de datos se considera un **ataque**. Para entender mejor estos ataques, podemos dividirlos en **cuatro grandes grupos**: **intercepción, interrupción, modificación y fabricación (o inserción)**. Además, según la **naturaleza** de cada ataque, es posible **clasificarlos** en **pasivos** (principalmente basados en la “escucha” o espionaje) o **activos** (alteran de forma directa el contenido o el flujo de la comunicación).

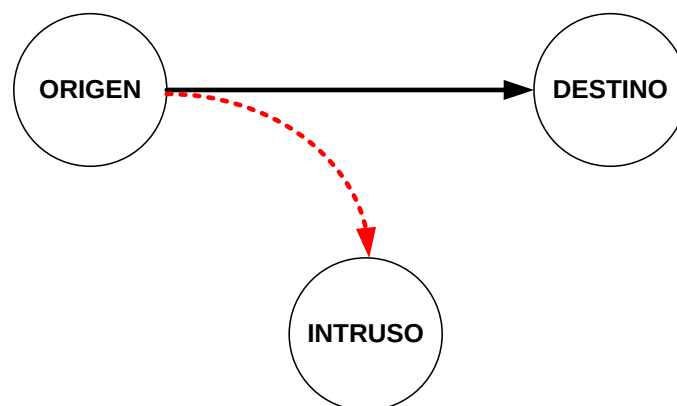
Intercepción (Ataques pasivos)

Un ataque de **intercepción** consiste en **espíar** o **escuchar** la comunicación entre dos puntos, con el objetivo de **obtener la información** que se está transmitiendo sin autorización. Lo característico de estos ataques es que el agresor no modifica el contenido del mensaje ni altera la continuidad de la comunicación; simplemente la observa de manera secreta.

Ejemplos

- **Sniffing de red**: Mediante herramientas como Wireshark, el atacante “captura” los paquetes que viajan por la red y, si no están cifrados, puede leer su contenido (usuarios, contraseñas, correos, etc.).
- **Eavesdropping Wi-Fi**: En redes inalámbricas mal protegidas (por ejemplo, con cifrado WEP o sin cifrado), un atacante puede escuchar el tráfico que circula entre los dispositivos y el punto de acceso.
- **Man-in-the-Middle “silencioso”**: A veces, un ataque MITM puede limitarse a observar la comunicación sin alterar nada (simplemente se sitúa en medio del flujo de datos para espíar).

Estos ataques se consideran **pasivos** porque el atacante no interfiere activamente en la comunicación, por lo que a menudo **pasan desapercibidos**.



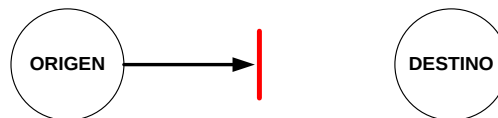
Interrupción (ataques activos)

Los ataques de **interrupción** buscan **romper o impedir** el flujo normal de la comunicación entre emisor y receptor. En este caso, el agresor **altera** la disponibilidad del servicio o de los datos, dejando al receptor (o incluso al emisor) sin acceso a la información.

Ejemplos

- **Ataques de Denegación de Servicio (DoS):** Se inunda el servidor con numerosas peticiones falsas o excesivas, saturándolo hasta el punto de no poder atender a usuarios legítimos.
- **Corte de cables o sabotaje físico:** A veces, el ataque es tan sencillo como cortar el cable de red o desconectar la infraestructura para que el servicio quede inaccesible.
- **Interrupción de energía:** Si un atacante provoca un apagón en el centro de datos (por ejemplo, manipula la alimentación eléctrica), se consigue interrumpir por completo las comunicaciones.

Este tipo de ataques se **clasifica como “activo”** porque hay una interferencia directa en el servicio, y sus consecuencias se hacen evidentes al usuario final.



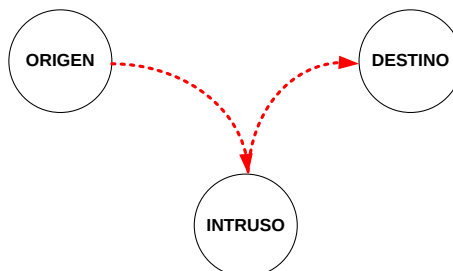
Modificación (ataques activos)

En un **ataque de modificación**, el agresor no solo intercepta los datos, sino que además los **cambia** o **manipula** de alguna manera antes de que lleguen a su destino. Esto puede alterar seriamente la integridad y confiabilidad de la información.

Ejemplos

- **Man-in-the-Middle con alteración de datos:** El atacante intercepta los mensajes y cambia, por ejemplo, números de cuenta bancaria o direcciones de envío, de modo que la víctima termina transfiriendo fondos o datos a un destino fraudulento.
- **Ataques de spoofing:** Un clásico es la “ARP spoofing” (engaño ARP), donde el atacante hace que una máquina crea que la dirección MAC del agresor es en realidad la de otro equipo. De este modo, todo el tráfico pasa por el atacante, que puede modificar paquetes en tránsito.
- **Corrupción de archivos en tránsito:** Se intercepta un archivo enviado por correo electrónico y se modifica para insertar malware o para alterar su contenido.

De nuevo, se trata de **ataques activos** porque implican una intervención directa que cambia el contenido de la comunicación.



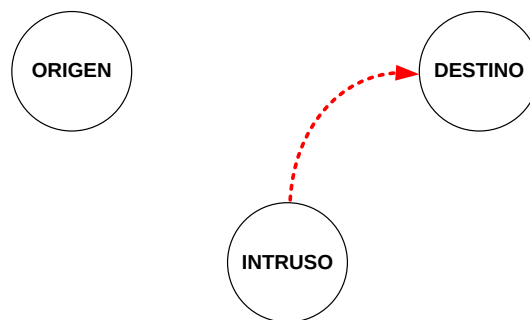
Fabricación o inserción (ataques activos)

La **fabricación** (o inserción) consiste en **crear datos o mensajes falsos** y transmitirlos como si fueran legítimos dentro de la red, engañando a los destinatarios y haciéndoles creer que provienen de la fuente original.

Ejemplos

- **Emisión de correos falsos (phishing):** Se generan emails que parecen legítimos (con la dirección y el formato de la empresa real) para engañar a los usuarios y robar credenciales.
- **Inyección de paquetes:** El atacante introduce paquetes ilegítimos en la red (por ejemplo, falsificando direcciones IP) para suplantar a otro equipo.
- **Ataques de "replay":** Se capturan mensajes legítimos y se reenvían más tarde (o repetidamente) con la intención de confundir al receptor o de ganar acceso no autorizado a un sistema que reconozca esos mensajes como válidos.

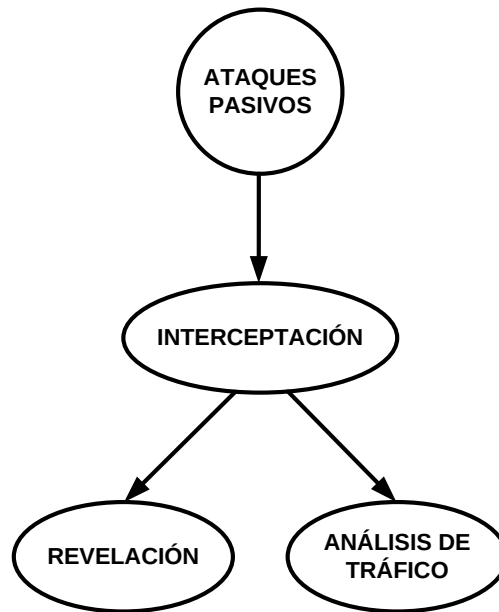
La **fabricación** también es un ataque **activo**, pues se interfiere abiertamente en la comunicación al **crear o agregar** datos que no existían.



3.4.1. Clasificación según la naturaleza del ataque

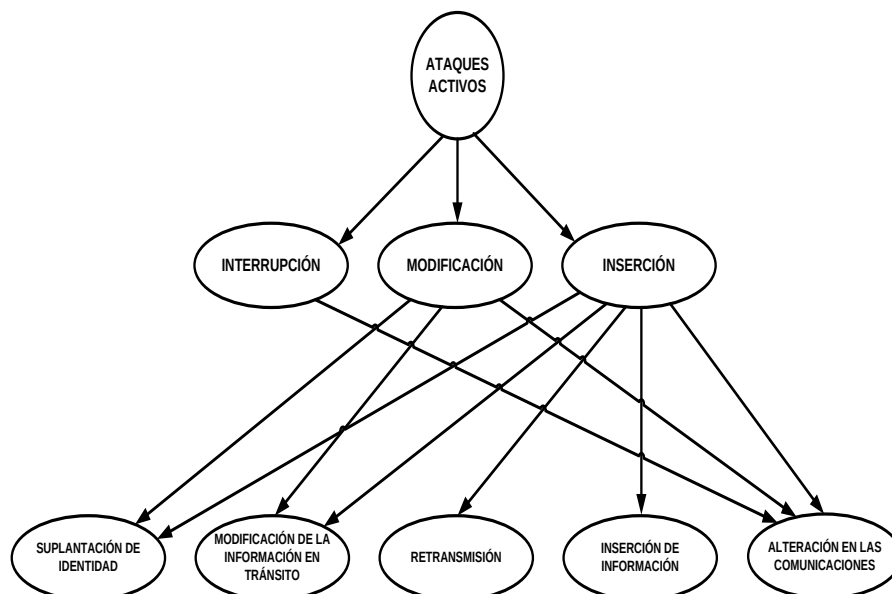
1. Ataques pasivos

- Se centran en la **intercepción** de la información.
- El atacante se limita a escuchar o copiar los datos sin alterar su flujo ni su contenido.
- Son peligrosos porque pueden pasar inadvertidos durante mucho tiempo y permitir la obtención de datos sensibles.



2. Ataques activos

- **Interrupción, modificación o fabricación.**
- Tratan de distorsionar, destruir o falsificar la información que se intercambia, o bien **bloquear** la comunicación por completo.
- Suelen ser más notorios, pero también pueden ocasionar daños inmediatos (pérdida de servicio, manipulación de datos críticos).



3.5. Servicios de Seguridad

La norma **ISO 7498-2**, también conocida como la **Arquitectura de Seguridad de la ISO/OSI**, describe los aspectos de seguridad que deben contemplarse en las redes de comunicaciones. Define **cinco categorías** de servicios de seguridad que buscan proteger la información que viaja por la red y a sus usuarios. Asimismo, establece **mecanismos** para implementar esos servicios de manera eficaz. A continuación, se detallan cada uno de estos servicios y los mecanismos, acompañados de ejemplos:

3.5.1. Confidencialidad

La **confidencialidad** garantiza que la información solo pueda ser vista o utilizada por las personas (o sistemas) autorizadas.

- **Ejemplo:** Un mensaje enviado por correo electrónico corporativo que contiene información sensible (contratos, datos personales, etc.) debe viajar cifrado para que, si un atacante lo intercepta, no pueda leerlo.
- **Implementación típica:**
 - **Cifrado** de los datos (por ejemplo, utilizando **AES** para cifrado simétrico o **RSA** en un esquema asimétrico).
 - **VPNs (Redes Privadas Virtuales)** que encapsulan y cifran todo el tráfico.

3.5.2. Autenticación

La **autenticación** busca asegurar que los usuarios o sistemas que participan en una comunicación sean realmente quienes dicen ser.

- **Ejemplo:** Al acceder a un servicio de banca en línea, el sistema verifica la identidad del usuario mediante contraseñas, tokens, autenticación de dos factores o certificados digitales.
- **Implementación típica:**
 - **Protocolos de intercambio de claves y autenticación** (por ejemplo, Kerberos, TLS con certificados X.509).
 - **Firmas digitales** que prueban la identidad del remitente en un correo o un documento electrónico.

3.5.3. Integridad

La **integridad** garantiza que los datos no sean alterados de forma no autorizada durante su transmisión o almacenamiento.

- **Ejemplo:** Si se transfiere un archivo contable desde una sede a otra, debe mantenerse inalterado. Para verificarlo, puede usarse un **hash** (por ejemplo, SHA-256). Si el hash de la información recibida coincide con el hash original, se confirma que no hubo cambios en el contenido.
- **Implementación típica:**
 - **Funciones de hash** (MD5, SHA-256, SHA-3, etc.) para crear resúmenes de los datos.
 - **Firmas digitales** que no solo autentican el origen, sino también aseguran que el contenido no haya sido modificado.

3.5.4. No repudio

El **no repudio** impide que una de las partes pueda negar haber participado en la comunicación o en la realización de una acción.

- **Ejemplo:** En el comercio electrónico, cuando un cliente realiza una compra en línea y la paga con su tarjeta, el sistema debe poder demostrar que esa persona efectivamente autorizó la transacción y no puede “desentenderse” de ella más tarde.
- **Implementación típica:**
 - **Registro de transacciones** con **sellos de tiempo** y **firmas digitales**.
 - **Autoridades de certificación** (CAs) que garantizan la validez de los certificados y el momento en que se firmó digitalmente un documento.

3.5.5. Control de acceso

El **control de acceso** se encarga de asegurar que solo las entidades debidamente autorizadas tengan permiso para usar un recurso o acceder a datos.

- **Ejemplo:** En una red corporativa, los empleados del departamento de Recursos Humanos pueden acceder a los expedientes de personal, pero no a las planificaciones de finanzas, y viceversa.
- **Implementación típica:**
 - **Sistemas de gestión de identidades y accesos (IAM)**, donde se configura qué roles o perfiles pueden acceder a ciertos datos o aplicaciones.
 - **Listas de control de acceso (ACLs)** en servidores y routers, para restringir el tráfico o los permisos de lectura/escritura.

3.6. Criptografía

Para **asegurar las comunicaciones**, la **criptografía** juega un papel fundamental. Sin embargo, existen diferentes formas de aplicar el cifrado en una red y distintos métodos (simétricos y asimétricos) para proteger la información

3.6.1. Cifrado de enlace vs. Cifrado extremo a extremo

Cifrado de enlace

Funcionamiento:

Cada tramo (enlace) de la comunicación entre nodos de la red está cifrado por dispositivos específicos (generalmente routers, pasarelas o multiplexores). Cuando el mensaje llega a un nodo intermedio, se **descifra** para poder determinar el siguiente salto o destino, se **encamina** correctamente y luego **se vuelve a cifrar** antes de enviarlo al siguiente nodo.

- **Ejemplo:**

Imaginemos un banco que interconecta sus sucursales mediante enlaces dedicados (cada sucursal se conecta a la sede central). En cada extremo de la línea alquilada, hay un dispositivo que cifra el tráfico. De esta manera, aunque alguien intercepte la conexión entre dos routers, los datos viajarán cifrados. Sin embargo, cuando llegan al router de destino, se descifran para su encaminamiento interno y se vuelven a cifrar si continúa el tránsito hacia otro enlace.

Ventajas y desventajas:

- **Ventaja:** Protege cada enlace de la red, dificultando la interceptación en medio de cada tramo.
- **Desventaja:** Como en cada nodo hay que descifrar y volver a cifrar, existe un riesgo de que, si un intruso logra acceder a ese nodo intermedio, pudiera leer el mensaje en texto claro.

Cifrado extremo a extremo

Funcionamiento:

Solo los dispositivos **finales** (emisor y receptor) realizan el cifrado y el descifrado. Así, el contenido del mensaje permanece protegido durante todo su trayecto a través de la red.

Cabecera no cifrada:

Es necesario dejar la **cabecera** (direcciones IP, puertos, etc.) sin cifrar para que los routers puedan dirigir el tráfico correctamente. Pero **la parte esencial del mensaje** (el cuerpo o payload) se envía cifrada de punta a punta.

- **Ejemplo:**

Si un usuario envía un correo electrónico usando cifrado extremo a extremo (por ejemplo, con GPG/PGP), este se cifra en el equipo del remitente y solo se descifra en el equipo del destinatario. Aunque el correo viaje por varios servidores de correo intermedios, en ningún momento se almacena el texto en claro.

Ventajas y desventajas:

- **Ventaja:** Mayor protección, puesto que la información no se descifra en nodos intermedios.
- **Desventaja:** Los routers no pueden inspeccionar el contenido para, por ejemplo, filtrar malware (a menos que se realicen técnicas especiales de inspección de tráfico cifrado).

3.6.2. Cifrado simétrico

El **cifrado simétrico** emplea la **misma clave** para cifrar y descifrar el mensaje.

Sus Características principales son:

1. **Una sola clave compartida:**
Emisor y receptor han de conocer (y mantener en secreto) la misma clave.
2. **Rapidez:**
Suele ser mucho más rápido que el cifrado asimétrico, por lo que se utiliza para proteger grandes volúmenes de datos (p. ej., discos duros, conexiones VPN, etc.).
3. **Seguridad basada en la complejidad del algoritmo y en la longitud de la clave:**
Es vital que el algoritmo sea resistente y que la clave sea lo bastante larga para evitar ataques de fuerza bruta. Por ejemplo, AES (Advanced Encryption Standard) con claves de 128, 192 o 256 bits.

4. Confidencialidad, integridad y a veces autenticación:

- Principalmente garantiza la **confidencialidad** (que nadie no autorizado lea el contenido).
- Puede combinarse con sumas de verificación o MAC (Message Authentication Codes) para asegurar la **integridad** y la autenticación del mensaje.

Ejemplo práctico

- **Almacenamiento cifrado:**

Un usuario protege el disco de su laptop con AES-256. Si un ladrón roba la computadora y extrae el disco duro, no podrá acceder a los datos sin la clave simétrica.

- **VPN:**

En una VPN IPsec, tras un intercambio inicial de claves, el tráfico se cifra con un algoritmo simétrico (como AES) para garantizar una buena velocidad y seguridad.



Ilustración 6. Funcionamiento del cifrado simétrico. Fuente: UAX Redes

3.6.3. Implementaciones típicas de Cifrado Simétrico

AES (Advanced Encryption Standard)

- Adoptado como estándar por el NIST (Instituto Nacional de Estándares y Tecnología de EE. UU.).
- Maneja longitudes de clave de 128, 192 o 256 bits.
- Se caracteriza por su rapidez y eficacia, por lo que es muy utilizado en VPN, discos cifrados, Wi-Fi (WPA2/WPA3), etc.

DES (Data Encryption Standard) y 3DES (Triple DES)

- DES fue uno de los primeros algoritmos simétricos estándar; hoy se considera inseguro debido a su corta longitud de clave (56 bits).
- 3DES aplica tres pasadas de cifrado DES con distintas claves y, aunque más seguro que DES, su velocidad es menor que AES y su uso está en declive.

RC4

- Algoritmo de flujo muy simple y rápido.
- Ampliamente utilizado en protocolos antiguos como WEP y TLS anteriores, aunque hoy en día se desaconseja por vulnerabilidades encontradas en su implementación.

ChaCha20

- Algoritmo de flujo moderno que ofrece rapidez y seguridad.
- Cada vez se emplea más como alternativa a AES (especialmente en dispositivos con recursos limitados), por ejemplo en TLS a través de la suite ChaCha20-Poly1305.

3.6.4. Cifrado asimétrico

El **cifrado asimétrico** emplea dos claves: **una pública y otra privada**.

Características principales

1. **Par de claves:**
 - **Clave pública:** Se puede distribuir abiertamente (no necesita ser secreta).
 - **Clave privada:** Debe mantenerse en secreto y nunca abandonar el dispositivo.
2. **Cifrado y descifrado con claves opuestas:**
Si cifras con la clave pública de alguien, **solo** la clave privada correspondiente puede descifrar el contenido, y viceversa.
3. **Más lento** y con claves **mucho más largas** que en el cifrado simétrico, razón por la que se utiliza a menudo para:
 - Establecer una clave simétrica segura a través de un canal inseguro (intercambio de claves).
 - Firmar digitalmente mensajes y garantizar autenticidad/no repudio.
4. **Confidencialidad y autenticación:**
 - Si usas la **clave pública** del destinatario para cifrar, solamente ese destinatario podrá descifrar con su clave privada (confidencialidad).
 - Si firmas un mensaje con tu **clave privada**, cualquiera que use tu **clave pública** puede verificar que lo has firmado tú (autenticación/no repudio).

Ejemplo práctico

- **Correo seguro (con PGP):**
Si quieres enviar un mensaje confidencial, tomas la clave pública del destinatario y cifras el mensaje. Nadie más que él, con su clave privada, podrá descifrarlo.
- **Firma digital:**
Un desarrollador firma su software con su clave privada. Los usuarios, al descargar el software, usan la clave pública del desarrollador para verificar la firma y asegurarse de que no ha sido modificado por un tercero.

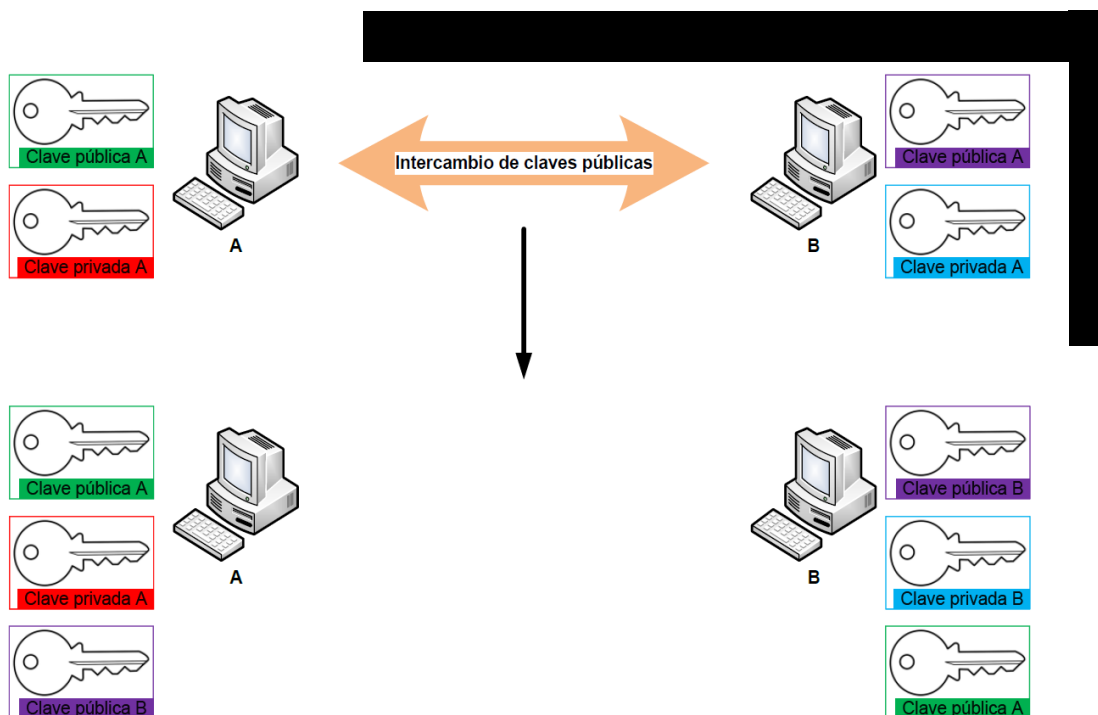


Ilustración 7. Proceso de intercambio de claves entre A y B. Fuente: UAX Redes

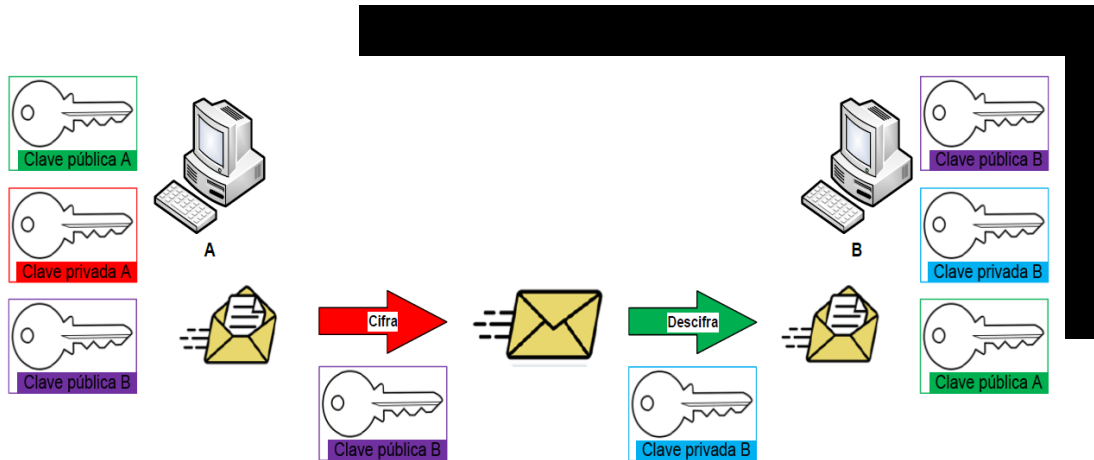


Ilustración 8. Cifrado de un mensaje usando cifrado asimétrico. Fuente: UAX Redes

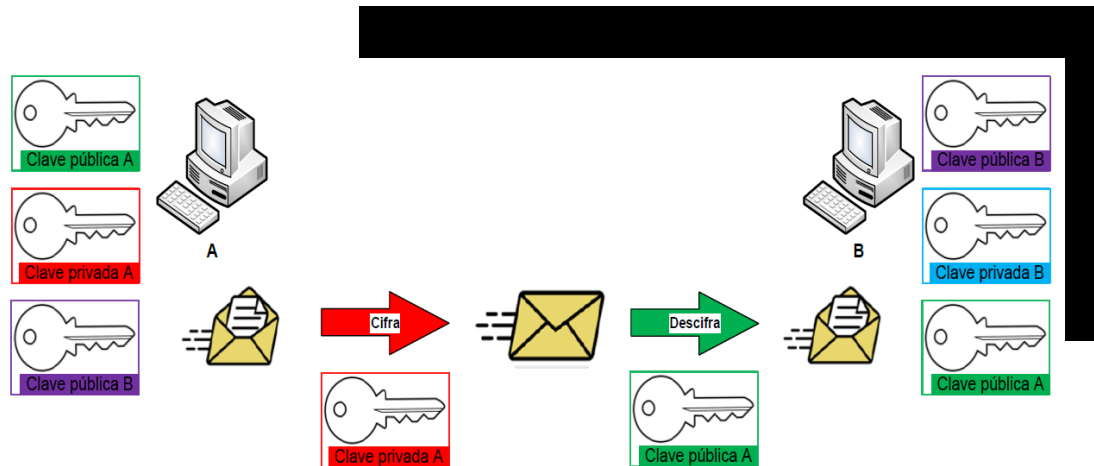


Ilustración 9. Asegurando identidad con cifrado asimétrico. Fuente: UAX Redes

3.6.5. Implementaciones mas comunes de Cifrado asimétrico

Diffie-Hellman (1976)

- **Primer sistema de cifrado asimétrico.**
- Permite a dos partes establecer una **clave secreta compartida** a través de un canal inseguro.
- La versión basada en **curvas elípticas (ECDH)** es más eficiente y usa claves más pequeñas para ofrecer un nivel de seguridad equivalente al de RSA con claves más grandes.
- **Limitación:** No provee autenticación por sí mismo, lo que motivó el desarrollo de algoritmos más completos.

RSA (1977)

- Desarrollado en el MIT por **Rivest, Shamir y Adleman**; se volvió rápidamente el estándar de cifrado asimétrico.
- Se basa en la **factorización** de un número muy grande (producto de dos primos).
- Admite cifrar con la **clave pública** y descifrar con la **privada**, o viceversa (útil para firmas digitales).
- **Longitud de clave recomendada**: al menos 1024 bits (idealmente 2048 bits o más).
- **Poco eficiente** para grandes volúmenes de datos; se usa sobre todo para **intercambiar una clave simétrica** que luego cifrará el resto de la información.

DSA y ECDSA (Digital Signature Algorithm)

- Orientados específicamente a la **firma digital**, se basan también en la teoría de grupos (DSA) o en curvas elípticas (ECDSA).
- Son ampliamente utilizados en aplicaciones que requieren autenticación y no repudio, como GPG, SSH o transacciones bancarias.

ElGamal

- Algoritmo menos usado en la práctica que RSA, pero interesante por su base matemática (también parte de la dificultad de problemas en grupos).
- Suele emplearse como método para cifrado y firma, aunque la implementación más común es la de **firma digital** dentro de GPG.

3.6.6. Uso combinado: negociación de claves

Dado que el cifrado simétrico es **rápido** y el **asimétrico** es más **seguro** para intercambiar claves (pero más lento para grandes volúmenes), lo habitual es **combinar** ambos:

1. **Inicio de conexión con cifrado asimétrico:**
Se genera una clave simétrica temporal (session key) que se envía cifrada con la clave pública del receptor.
2. **Uso de cifrado simétrico para el resto de la comunicación:**
Una vez ambos extremos conocen la misma clave de sesión, todo el tráfico posterior se cifra y descifra con esa clave simétrica, garantizando eficiencia y confidencialidad.

Ejemplo:

- En **TLS/SSL** (el protocolo de seguridad que cifra el tráfico web en HTTPS), el navegador y el servidor intercambian claves mediante algoritmos asimétricos (RSA o DH), pero luego emplean un algoritmo simétrico (AES, ChaCha20, etc.) para cifrar el tráfico principal de la sesión.

3.6.7. Funciones Hash

Las **funciones hash** se diferencian de los algoritmos de cifrado (simétricos o asimétricos) en que **no** están diseñadas para recuperar el mensaje original, sino para **producir una huella digital** (resumen o **digest**) que permita verificar si un mensaje o archivo ha sido alterado.

Longitud de salida fija	Independientemente de si el mensaje de entrada (texto, fichero, etc.) ocupa unas pocas líneas o varios gigabytes, la función hash produce siempre una cadena de bits de longitud fija. Por ejemplo, SHA-256 genera un resultado de 256 bits (64 caracteres hexadecimales), mientras que SHA-1 genera 160 bits (40 caracteres hexadecimales).
Resistencia a colisiones	Se busca que sea extremadamente improbable que dos mensajes distintos produzcan la misma salida. En otras palabras, que encontrar dos entradas diferentes con el mismo hash (colisión) sea computacionalmente inviable.
Imposibilidad de reconstruir el mensaje original	Las funciones hash están concebidas como unidireccionales. Conocer el valor hash no permite, en la práctica, deducir el mensaje de origen. Esto contrasta con la criptografía simétrica o asimétrica, donde sí es posible (y necesario) descifrar el contenido.
Integridad de la información	Su objetivo principal es comprobar que no ha habido alteraciones en los datos entre el emisor y el receptor. Si alguien modifica tan solo un bit del mensaje original, el resultado del hash cambiará drásticamente (propiedad conocida como avalancha o efecto avalancha).
Aplicaciones típicas	Verificación de descargas: Cuando descargas un archivo (por ejemplo, una ISO de un sistema operativo), el sitio oficial te proporciona el hash (SHA-256, etc.) para que puedas comprobar que tu archivo coincide exactamente con el original. Almacenamiento seguro de contraseñas: En lugar de guardar las contraseñas en texto plano, se almacena el hash. Cuando un usuario inicia sesión, se calcula el hash de la contraseña ingresada y se compara con el guardado. Firma digital: A menudo, en la firma digital se aplica primero una función hash al documento, y luego se firma ese hash con la clave privada. De este modo, se facilita y agiliza el proceso, ya que firmar directamente un documento muy grande podría ser ineficiente.

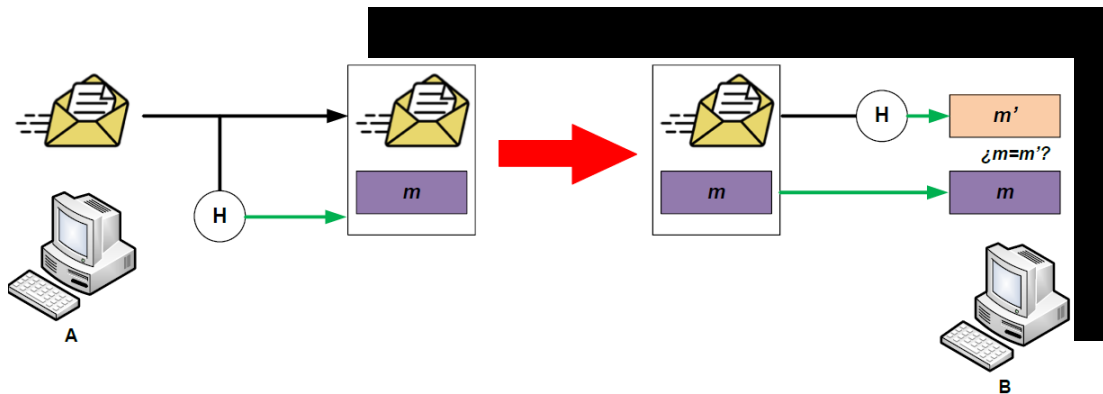


Ilustración 10. Uso de función Hash. Fuente: UAX Redes

Ejemplo sencillo de uso

1. Creación de la huella digital:

- Tienes un documento de 500 páginas. Le pasas una función hash (p. ej. SHA-256) y obtienes un resumen de 64 caracteres hexadecimales.

2. Envío y verificación:

- Mandas el documento junto con el hash a un colaborador.
- Tu colaborador vuelve a aplicar la misma función hash al documento recibido.
- Si el hash calculado localmente **coincide** con el que tú le proporcionaste, el colaborador sabe que el archivo **no ha sido modificado** en el trayecto.

3.6.8. Firma digital

La **firma digital** no es ni un mecanismo de cifrado ni una simple función hash, sino un **proceso** que aprovecha las propiedades de la **criptografía asimétrica** para brindar **no repudio** y verificar la autenticidad de un mensaje. Los objetivos de la firma digital son los siguientes

Verificar la identidad del transmisor	El receptor puede comprobar que quien firma el mensaje es efectivamente el titular de la clave privada asociada. Así, se garantiza que el emisor no sea suplantado por un tercero.
No repudio	El transmisor no puede negar posteriormente haber firmado el mensaje. Esto implica que existan evidencias que prueben que la firma solo pudo haber sido generada por la persona (o entidad) que posee la clave privada.

Imposibilidad de falsificación por parte del receptor	El receptor no puede modificar el contenido ni elaborar el mensaje y decir que lo firmó el emisor, ya que no posee la clave privada del firmante.
No garantiza confidencialidad	La firma digital, por sí sola, no cifra el contenido; únicamente firma (sella) el mensaje. Para asegurar que el contenido sea privado, es necesario combinarla con un mecanismo de cifrado (simétrico o asimétrico).

Funcionamiento básico

1. El emisor calcula un **hash** (resumen) del mensaje.
2. Cifra ese resumen con su **clave privada** asimétrica, produciendo la “firma digital”.
3. Envía el mensaje original (o su hash) junto con la firma al receptor.
4. El receptor recibe el mensaje:
 - Vuelve a hacer el **hash** del mismo.
 - **Descifra** la firma usando la **clave pública** del emisor.
 - Si el resultado coincide con el hash recalculado, sabe que:
 - El mensaje no ha sido alterado (integridad).
 - La firma procede de la persona dueña de la clave privada (autenticidad).

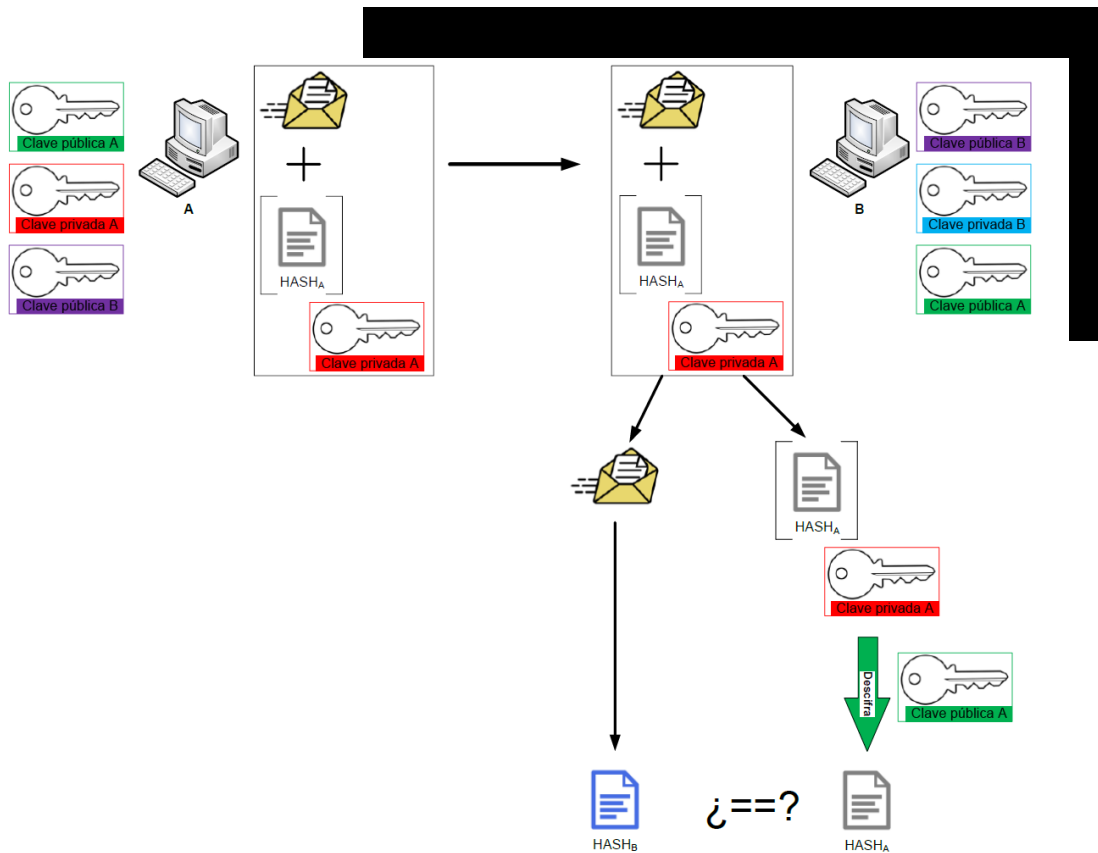


Ilustración 11. Uso de firma digital. Fuente: UAX Redes

Rol de la entidad certificadora (CA)

- Para confiar en la **clave pública** de alguien, se requiere que un **tercero de confianza** (la autoridad de certificación) “avale” esa vinculación entre la clave pública y la identidad del firmante.
- El certificado digital expedido por la CA prueba que una clave pública pertenece a cierto usuario o entidad, dando mayor legitimidad y evitando ataques de suplantación.

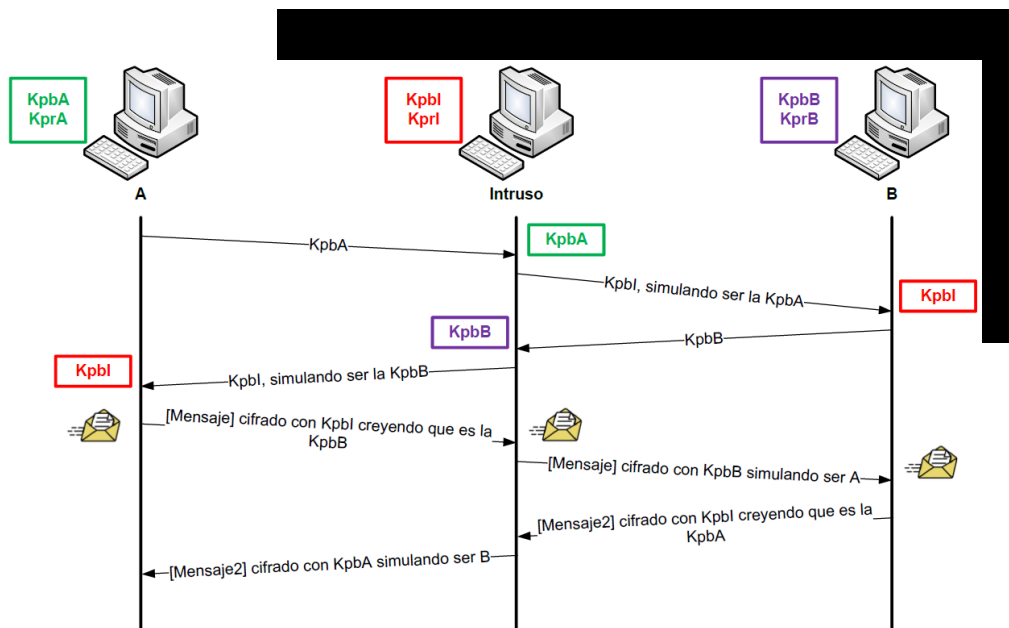


Ilustración 12. Ejemplo de interceptación. Fuente: UAX Redes

4. Conclusiones

El ciberespacio ha dejado de ser una simple plataforma de interacción para convertirse en un entorno crítico que influye en la estabilidad y la prosperidad de las naciones. Comprender su funcionamiento, sus riesgos y sus posibilidades resulta esencial para participar de manera segura y efectiva en la sociedad digital, así como para proteger los intereses de organizaciones públicas y privadas en un mundo cada vez más interconectado.

La seguridad física es la primera barrera que debe reforzarse para garantizar la protección de los equipos. Una combinación de control de accesos (prevención), sistemas de alarma (detección) y planes de contingencia para catástrofes naturales o provocadas (recuperación) proporciona un marco sólido para resguardar los activos más costosos y sensibles de la organización. A esto se suma la gestión adecuada del factor humano —a través de la formación, la concienciación y la definición clara de responsabilidades—, así como el mantenimiento y configuración segura del software que corre en el hardware.

La comunicación “normal” en una red significa un tráfico de datos sin interferencias ni espionaje. Cualquier acción que rompa esa normalidad —ya sea escuchando, interrumpiendo, alterando o fabricando información— se considera un ataque. Entender las diferencias entre ataques pasivos (basados en la interceptación) y ataques activos (interrupción, modificación y fabricación) resulta esencial para diseñar estrategias de seguridad adecuadas, que incluyan cifrado para protegerse de escuchas, sistemas de detección de intrusos y planes de contingencia ante posibles interrupciones o manipulaciones de la información.

Para asegurar las comunicaciones, se pueden cifrar los datos a diferentes niveles (cifrado de enlace o extremo a extremo), cada uno con sus ventajas y desventajas en cuanto a dónde se descifra la información y cómo se encamina. Además, existen dos grandes paradigmas de cifrado:

- Cifrado simétrico: Usa una misma clave compartida, es más rápido y se suele emplear para grandes volúmenes de datos.
- Cifrado asimétrico: Usa dos claves (pública y privada), y resulta más flexible para establecer comunicaciones seguras sin que las partes se conozcan de antemano, además de permitir la firma digital.

Lo habitual en la práctica es combinar ambos métodos para aprovechar lo mejor de cada uno: la facilidad de intercambio de claves que ofrece el cifrado asimétrico y la rapidez del cifrado simétrico para la comunicación continua. De esta forma, se garantiza tanto la confidencialidad y la integridad de los datos como la autenticación de las partes que se comunican.

Las funciones hash son un pilar esencial de la seguridad informática, pues garantizan la integridad de los datos sin necesidad de descifrar contenido (como en la criptografía tradicional).

La firma digital se centra en la autenticidad y el no repudio, permitiendo que el receptor verifique el origen del mensaje y que el emisor no pueda negar su autoría. Sin embargo, no proporciona confidencialidad por sí misma: para que el contenido viaje protegido, hace falta

combinarla con un algoritmo de cifrado. De esta forma, se consiguen tanto la privacidad de la comunicación como la certeza de la identidad y la integridad del mensaje.

Teniendo todo esto en consideración estamos preparados para comenzar a aplicar lo aprendido para la asignatura de Redes ¡Adelante!

5. Bibliografía

Redes. Asignatura OpenUax (Versión anterior)

Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice*.

Menezes, A.J., van Oorschot, P.C., & Vanstone, S.A. (1996). *Handbook of Applied Cryptography*.

RSA Laboratories. (2002). *PKCS #1: RSA Cryptography Standard*.

FIPS 186-4 (2013): *Digital Signature Standard (DSS)*.

WELCOME
TO
UAX

UAX

Universidad
Alfonso X el Sabio

G R A C I A S

UAX.COM